

Estudio de Estándares: NIST CSF 2.0, CIS Controls v8.1 y Ley 25.326

Esta sección desarrolla los tres marcos de referencia definidos en la Etapa 1 del plan de trabajo: el NIST Cybersecurity Framework 2.0, los CIS Controls v8.1 (junto con su guía complementaria para Inteligencia Artificial y Modelos de Lenguaje Grande), y la Ley 25.326 de Protección de Datos Personales de la República Argentina. El objetivo es identificar, en cada marco, los elementos que fundamentan y orientan el diseño de la extensión de navegador, el dashboard de administración y el motor de análisis de riesgo.

2.1 NIST Cybersecurity Framework (CSF) 2.0

El NIST Cybersecurity Framework fue desarrollado originalmente por el National Institute of Standards and Technology (NIST) a partir de la Orden Ejecutiva 13636 de 2013, con el fin de establecer buenas prácticas de ciberseguridad para infraestructura crítica. Su versión 2.0, publicada en febrero de 2024 tras un proceso de borrador público iniciado en 2023, amplía el alcance del marco: deja de estar orientado exclusivamente a infraestructura crítica y pasa a aplicarse a organizaciones de cualquier tamaño y sector, incluidas las pequeñas y medianas empresas.

La principal novedad estructural del CSF 2.0 es la incorporación de una sexta función, Gobernar (Govern), que se suma a las cinco funciones originales: Identificar, Proteger, Detectar, Responder y Recuperar. La función Gobernar se ubica conceptualmente en el centro del modelo, ya que define la estrategia, las políticas y la asignación de responsabilidades que orientan a las cinco funciones operativas restantes. En conjunto, el CSF 2.0 organiza sus funciones en 22 categorías y 106 subcategorías de resultados esperados.

Para este proyecto, las funciones más relevantes son Identificar (reconocer el uso de herramientas de IA generativa como una superficie de riesgo dentro de la PyME) y Detectar (contar con mecanismos que permitan advertir, en tiempo real, eventos de posible exposición de datos). El sistema desarrollado aporta evidencia concreta a ambas funciones, mientras que los eventos registrados en el dashboard de administración pueden alimentar, en una segunda instancia, decisiones propias de la función Gobernar (por ejemplo, la definición de una política interna de uso de IA).

2.2 CIS Controls v8.1 y su guía complementaria para IA y LLMs

Los CIS Controls, mantenidos por el Center for Internet Security (CIS), constituyen un conjunto priorizado de salvaguardas técnicas y organizacionales orientado a mitigar los patrones de ataque más frecuentes, sobre la base de datos reales de incidentes. La versión 8.1, publicada en junio de 2024, organiza 153 salvaguardas en 18 controles, y se alinea explícitamente con las funciones del NIST CSF 2.0. Un aporte distintivo del marco son los Grupos de Implementación (IG1, IG2 e IG3): IG1 reúne 56 salvaguardas de higiene cibernética esencial, pensadas para organizaciones pequeñas o con recursos limitados, mientras que IG2 e IG3 suman salvaguardas adicionales para organizaciones de mayor complejidad y exposición al riesgo.

Esta estructura por grupos de implementación resulta especialmente relevante para el proyecto: el sistema propuesto puede entenderse como una salvaguarda de nivel IG1, es decir, una medida de

higiene básica viable para una PyME sin equipo de seguridad dedicado, en lugar de una solución de nivel corporativo (IG3) como las plataformas CASB mencionadas en los antecedentes.

En abril de 2026, el CIS publicó, junto con las empresas Astrix Security y Cequence Security, un conjunto de tres guías complementarias que interpretan los CIS Controls v8.1 a la luz de los riesgos propios de los sistemas de IA: la guía de Inteligencia Artificial y Modelos de Lenguaje Grande (AI/LLM Companion Guide), la guía de Agentes de IA y la guía de Protocolo de Contexto de Modelo (MCP). Para este proyecto resulta especialmente relevante la primera, orientada a los riesgos de los LLMs vinculados a la exposición de datos a través de prompts y al manejo del contexto conversacional, ya que interpreta los controles existentes (gestión de activos, configuración segura, control de identidad y registro de eventos) bajo una óptica propia de los sistemas de IA generativa.

El término Shadow AI, si bien no es acuñado originalmente por el CIS, es ampliamente utilizado en la industria de la ciberseguridad —entre otros, por IBM— para describir el uso no autorizado o no supervisado de herramientas de IA generativa por parte de los empleados de una organización, sin aprobación ni conocimiento del área de sistemas. Se lo entiende como una extensión del fenómeno de Shadow IT (uso de software o servicios no aprobados) aplicada específicamente a asistentes conversacionales basados en LLMs. Su particularidad radica en que la interacción ocurre en lenguaje natural: el usuario no percibe que está transfiriendo información a un tercero externo, sino que vive la interacción como una conversación, lo que reduce su percepción de riesgo al compartir datos sensibles.

Este proyecto retoma el espíritu de los controles vinculados a la gestión de activos de datos y a la prevención de fuga de información, adaptándolo —normalmente pensado para soluciones empresariales complejas como Netskope o Microsoft Defender for Cloud Apps— a una implementación liviana y de bajo costo, alineada con el nivel IG1 y viable para una PyME sin infraestructura ni personal especializado.

2.3 Ley 25.326 — Protección de los Datos Personales (Argentina)

La Ley 25.326, sancionada por el Congreso de la Nación Argentina en el año 2000 y reglamentada por el Decreto 1558/2001, tiene por objeto la protección integral de los datos personales asentados en archivos, registros o bancos de datos, con el fin de garantizar el derecho al honor y a la intimidad de las personas. Su autoridad de control es actualmente la Agencia de Acceso a la Información Pública (AAIP).

El artículo 2 de la ley define dato personal como toda información referida a personas físicas o jurídicas determinadas o determinables, y establece una categoría diferenciada de dato sensible: aquel que revela origen racial y étnico, opiniones políticas, convicciones religiosas, filosóficas o morales, afiliación sindical, o información referente a la salud o a la vida sexual. El artículo 7 restringe fuertemente la recolección y el tratamiento de esta categoría de datos, mientras que el artículo 9 impone al responsable del tratamiento el deber de adoptar las medidas técnicas y organizativas necesarias para garantizar su seguridad y confidencialidad, un deber que la Resolución AAIP 47/2018 refuerza recomendando niveles de seguridad más altos para los datos sensibles que para los datos personales en general.

Para el diseño del sistema, esta normativa aporta el criterio legal de base sobre qué constituye un dato sensible en el contexto argentino. Sin embargo, dado que la mayor parte de la información que una PyME expone habitualmente a herramientas de IA externa —identificadores como CUIT o CBU, datos de contacto de clientes, información contractual o financiera— corresponde a la categoría más amplia de dato personal (y no siempre a la categoría estricta de dato sensible del artículo 2), el diseño de los mensajes contextuales de la extensión adoptará un criterio de sensibilidad ampliado, que combine la definición legal con las categorías de datos de negocio identificadas en el relevamiento (sección 3), a fin de resultar comprensible y accionable para un usuario no técnico.

2.4 Síntesis comparativa de los tres marcos

Marco	Naturaleza y alcance	Aporte al proyecto
NIST CSF 2.0	Marco voluntario de gestión de riesgo de ciberseguridad, seis funciones (Gobernar, Identificar, Proteger, Detectar, Responder, Recuperar), aplicable a organizaciones de cualquier tamaño.	Ubica al sistema dentro de las funciones Identificar y Detectar, y sienta las bases para una futura política de uso de IA (función Gobernar).
CIS Controls v8.1 + AI/LLM Companion Guide	153 salvaguardas técnicas priorizadas en 18 controles y 3 Grupos de Implementación; guía complementaria (2026) que las interpreta para sistemas de IA y LLMs.	Ubica al sistema como una salvaguarda de nivel IG1, viable sin equipo de seguridad dedicado, y aporta el concepto de Shadow AI como problema a mitigar.
Ley 25.326	Marco legal argentino de protección de datos personales; define dato personal y dato sensible y establece deberes de seguridad en su tratamiento.	Aporta el criterio legal de sensibilidad de datos que sustenta las explicaciones en lenguaje simple que despliega la interfaz de intervención contextual.

Referencias Bibliográficas

1. National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce. Recuperado de <https://www.nist.gov/cyberframework>
2. Center for Internet Security. (2024). *CIS Critical Security Controls, versión 8.1*. CIS. Recuperado de <https://www.cisecurity.org/controls>
3. Center for Internet Security, Astrix Security y Cequence Security. (2026). *Artificial Intelligence and Large Language Models (AI/LLM) Companion Guide to CIS Controls v8.1*. CIS. Recuperado de <https://www.cisecurity.org/insights/white-papers/controls-v8-1-ai-llm-companion-guide>
4. IBM. (2025). *What is shadow AI?* IBM Think. Recuperado de <https://www.ibm.com/think/topics/shadow-ai>

5. Congreso de la Nación Argentina. (2000). *Ley 25.326 — Protección de los Datos Personales* (texto actualizado). Recuperado de <https://www.argentina.gob.ar/normativa/nacional/ley-25326-64790/texto>
6. Agencia de Acceso a la Información Pública. (2018). *Resolución AAIP 47/2018 — Medidas de seguridad para el tratamiento de datos personales*. Recuperado de <https://www.argentina.gob.ar/aaip>